Part A — Case Studies

Case Study 1 — Proxy Server for Web Access Control

A college has a large computer laboratory used by students and faculty. The network administrator wants to improve web security and control Internet usage. Instead of allowing every computer to communicate directly with websites, the administrator deploys a **proxy server** between the laboratory network and the Internet.

The proxy server is configured to:

- Receive web requests from client computers.
- Forward permitted requests to external websites.
- Block access to selected categories of websites.
- Maintain logs of web requests.
- Apply access policies based on users or groups.
- Cache frequently requested content where appropriate.

After deployment, the administrator notices that some users are attempting to access restricted websites. The proxy blocks these requests and records the events in its logs.

Questions

1. What role does the proxy server play in this network?
2. Why is logging important in this scenario?
3. How can a proxy server help enforce an organization's Internet-use policy?
4. What is the difference between a proxy server and a firewall?
5. Why should proxy logs be protected from unauthorized modification?
6. What problems could occur if the proxy server becomes unavailable?
7. Why should proxy rules be reviewed periodically?

Case Study 2 — Vulnerability Assessment of a Web Application

An organization has developed an online fashion-retail application. Customers can register accounts, browse products, add items to a cart, and make payments.

Before deploying the application, the security team performs a **Vulnerability Assessment**. The team first defines the authorized scope and identifies the systems that may be tested. They then perform information gathering and vulnerability scanning using approved tools.

The assessment identifies several issues, including:

- Outdated software components.
- Weak security configurations.
- Missing security updates.
- Potentially vulnerable web application components.
- Services exposed unnecessarily to the Internet.

The security team documents each finding, including its affected asset, severity, evidence, and recommended remediation.

Questions

1. What is the primary objective of vulnerability assessment?
2. Why must the testing scope be defined before scanning?
3. What is the difference between vulnerability identification and vulnerability remediation?
4. Why should vulnerabilities be prioritized according to risk?
5. Why is documentation important during a vulnerability assessment?
6. What is the purpose of vulnerability-scanning tools such as Nessus or OpenVAS/Greenbone?
7. Why should identified vulnerabilities be verified before being reported as confirmed issues?

Case Study 3 — Authorized Penetration Testing

A company has authorized its cybersecurity team to conduct a penetration test against a staging environment containing a web server and database server. The objective is to determine whether identified vulnerabilities can actually be exploited and what impact they could have.

The penetration testers establish rules of engagement before beginning. They perform reconnaissance, enumerate services, identify potential weaknesses, and conduct controlled exploitation within the approved scope. They then document the evidence and assess the potential impact.

The testers discover that an outdated service could potentially provide unauthorized access. They stop further exploitation once sufficient evidence has been collected and do not attempt to access unrelated systems.

The final report contains:

- Executive summary.
- Scope and methodology.
- Identified vulnerabilities.
- Evidence.
- Risk/impact information.
- Remediation recommendations.

- Retesting requirements.

Questions

1. Why is authorization essential before penetration testing?
2. What is meant by the "scope" of a penetration test?
3. How does penetration testing differ from vulnerability scanning?
4. Why should penetration testers follow rules of engagement?
5. Why should exploitation be limited to what is necessary to demonstrate the issue?
6. What is the purpose of the final penetration-testing report?
7. Why is retesting important after remediation?

Part B

1. What is the primary function of a proxy server?

A. Act as an intermediary between clients and external services
B. Replace the operating system
C. Physically repair network cables
D. Encrypt every file stored on a computer

2. Which of the following can a proxy server commonly provide?

A. Web access control and traffic logging
B. CPU manufacturing
C. RAM expansion
D. Hardware replacement

3. Why are proxy logs useful to network administrators?

A. They can provide records of network requests and access activity
B. They automatically eliminate all vulnerabilities
C. They increase processor speed
D. They replace authentication mechanisms

4. A company wants employees' web requests to pass through an intermediary where access policies can be applied. Which technology is appropriate?

A. Proxy server
B. Keyboard
C. Database
D. Compiler

5. What is Vulnerability Assessment primarily concerned with?

A. Identifying and evaluating security weaknesses
B. Designing computer hardware
C. Increasing network bandwidth
D. Creating user-interface designs

6. What does VAPT generally stand for?

A. Vulnerability Assessment and Penetration Testing
B. Virtual Application Processing Technology
C. Verified Access Protection Tool
D. Vulnerability Analysis Programming Technique

7. Which activity generally involves identifying weaknesses in systems without necessarily exploiting them?

A. Vulnerability assessment
B. Data compression
C. Software compilation
D. Hardware installation

8. What is a major characteristic of penetration testing?

A. Authorized attempts to demonstrate whether security weaknesses can be exploited
B. Random attacks against Internet users

C. Testing without permission
D. Only checking whether a computer is switched on

9. Which activity commonly occurs during the reconnaissance phase?

A. Gathering information about the authorized target
B. Deleting production databases
C. Changing employee passwords without authorization
D. Destroying network equipment

10. Which tool is commonly associated with network discovery and service enumeration?

A. Nmap
B. Microsoft Paint
C. Calculator
D. Notepad

11. Which tool is commonly used for vulnerability scanning?

A. Nessus
B. VLC Player
C. Calculator
D. WordPad

12. Which of the following is an open-source vulnerability-management platform?

A. Greenbone/OpenVAS
B. Photoshop
C. PowerPoint
D. Winamp

13. What is the purpose of vulnerability scanning?

A. To identify potentially vulnerable systems, services, or configurations
B. To permanently disable all network services
C. To physically inspect cables
D. To increase monitor resolution

14. Why should the scope of a penetration test be clearly defined?

A. To ensure testing is performed only against authorized targets
B. To allow testers to attack any system they discover
C. To eliminate the need for documentation
D. To prevent all security testing

15. What is a "false positive" in vulnerability assessment?

A. A reported vulnerability that is not actually present or exploitable as reported
B. A confirmed security vulnerability
C. A successful software update
D. A correctly configured firewall

16. Which of the following should be established before an authorized penetration test?

A. Scope and rules of engagement
B. Random target selection
C. Unrestricted Internet access
D. Removal of all security controls

17. Which statement best describes the difference between vulnerability assessment and penetration testing?

A. Vulnerability assessment identifies weaknesses, while penetration testing attempts controlled exploitation to demonstrate impact
B. Both always have exactly the same objective
C. Penetration testing only checks software versions
D. Vulnerability assessment requires unauthorized access

18. What is enumeration?

A. Gathering detailed information about identified systems, services, or resources
B. Deleting security logs
C. Encrypting a hard disk
D. Formatting a server

19. Which tool is widely used for intercepting and analyzing HTTP/HTTPS requests during authorized web application testing?

A. Burp Suite
B. Calculator
C. File Explorer
D. Task Manager

20. What is the purpose of a penetration-testing report?

A. To document findings, evidence, impact, methodology, and remediation recommendations
B. To hide vulnerabilities from system owners
C. To provide unauthorized access credentials
D. To permanently disable the tested system

21. Why should identified vulnerabilities be prioritized?

A. Different vulnerabilities can have different levels of risk and business impact
B. Every vulnerability always has exactly the same impact
C. Prioritization makes documentation unnecessary
D. Only low-risk vulnerabilities need attention

22. Which practice is most appropriate when conducting an authorized penetration test?

A. Follow the approved scope and rules of engagement
B. Test unrelated third-party systems
C. Delete evidence after testing
D. Continue exploitation indefinitely

23. What is retesting?

A. Checking whether previously identified vulnerabilities have been successfully addressed
B. Reinstalling every computer in an organization
C. Repeating a password-generation exercise
D. Removing all security controls

24. Which sequence represents a reasonable high-level VAPT workflow?

A. Scope → Reconnaissance → Scanning/Enumeration → Validation/Testing → Reporting → Remediation/Retesting
B. Exploitation → Scope → Authorization → Reporting
C. Reporting → Unauthorized access → Reconnaissance → Scope
D. Remediation → Random scanning → Authorization

25. Why is authorization particularly important in penetration testing?

A. Testing can interact with systems and potentially affect their confidentiality, integrity, or availability
B. Authorization makes vulnerabilities disappear
C. Authorization automatically fixes security weaknesses
D. Penetration testing never affects systems